

1. Wireless Concepts

What is a Wireless Network (Wi-Fi)?

An unbounded data communication system that uses radio-frequency technology (electromagnetic waves) to communicate with devices without physical cables. Wi-Fi refers to Wireless Local Area Networks (WLANs) based on the IEEE 802.11 standard.

Wireless Terminology

- **GSM (Global System for Mobile Communications):** Universal system for mobile data transmission.
- **Bandwidth:** Amount of information that can be broadcast over a connection (data transfer rate in bps).
- **Access Point (AP):** Connects wireless devices to a wired/wireless network. Acts as a hub/switch.
 - **Software APs (SAPs):** Run on a computer with a wireless NIC.
 - **Hardware APs (HAPs):** Dedicated devices supporting most wireless features.
- **BSSID (Basic Service Set Identifier):** MAC address of an AP.
- **ISM Band (Industrial, Scientific, and Medical Band):** Frequencies used by international industrial, scientific, and medical communities.
- **Hotspot:** Places where wireless networks are available for public use.
- **Association:** Process of connecting a wireless device to an AP.
- **SSID (Service Set Identifier):** A 32-alphanumeric-character unique identifier for a WLAN. Devices must use the same SSID to connect.
- **OFDM (Orthogonal Frequency-Division Multiplexing):** Digital modulation method splitting a signal into multiple orthogonal carrier frequencies.
- **MIMO-OFDM (Multiple Input, Multiple Output-OFDM):** Influences spectral efficiency of 4G/5G, reduces interference, increases channel robustness.
- **DSSS (Direct-Sequence Spread Spectrum):** Multiplies original data signal with a pseudo-random noise-spreading code to protect against interference.
- **FHSS (Frequency-Hopping Spread Spectrum):** Rapidly switches a carrier among many frequency channels to decrease interception/jamming efficiency.

Types of Wireless Networks

- **Extension to a Wired Network:** APs extend wired networks to wireless devices.
- **Multiple Access Points:** Multiple APs used to cover a larger area, allowing roaming.
- **LAN-to-LAN Wireless Network:** Interconnecting local area networks wirelessly using APs.
- **3G/4G/5G Hotspot:** Provides Wi-Fi access to Wi-Fi-enabled devices via cellular networks.

Wireless Standards (IEEE 802.11 Amendments)

- **802.11 (Wi-Fi):** Original standard (1997), 1-2 Mbps, 2.4 GHz.
- **802.11a:** 5 GHz band, OFDM modulation, up to 54 Mbps.
- **802.11b:** 2.4 GHz band, DSSS modulation, up to 11 Mbps.
- **802.11g:** 2.4 GHz band, OFDM modulation, up to 54 Mbps.
- **802.11n:** 2.4/5 GHz bands, MIMO-OFDM, up to 600 Mbps.
- **802.11ac (Wi-Fi 5):** 5 GHz band, supports up to 9.6 Gbps.
- **802.11ax (Wi-Fi 6):** 2.4/5 GHz bands, 1024-QAM, up to 2.4 Gbps.
- **802.11be (Wi-Fi 7):** 2.4/5/6 GHz bands, QAM, up to 3 Gbps.
- **802.15.1 (Bluetooth):** Personal Area Networks (WPAN), 2.4 GHz.
- **802.15.4 (ZigBee):** Low-power, low-data rate wireless personal area networks.
- **802.16 (WiMAX):** Wireless Metropolitan Area Networks (WMAN), long-range.

Wi-Fi Authentication Process

- **Pre-shared Key (PSK) Mode (WPA-PSK or WPA2-PSK):** Uses a single shared password for all devices. Common for homes/small offices.
- **Centralized Authentication Mode (RADIUS):** Uses a centralized authentication server (RADIUS) for enterprise-level authentication with unique user credentials (WPA2-Enterprise).

Types of Wireless Antennas

- **Directional Antenna:** Transmits/receives radio waves from a single direction.
- **Omnidirectional Antenna:** Transmits/receives radio waves in all directions (360° horizontal pattern).
- **Parabolic Grid Antenna:** High-gain, long-range antenna.
- **Yagi Antenna:** Directional antenna, high gain, long signal-to-noise ratio.
- **Dipole Antenna:** Straight electrical conductor, half-wavelength.
- **Reflector Antennas:** Concentrate EM energy that is radiated/received at a focal point.

Service Set Identifier (SSID)

An SSID is a unique 32-character identifier for Wi-Fi networks, used by clients to locate and connect to access points. It offers no real security, as it's often transmitted in plaintext and defaults can be easily exploited.

2. Wireless Encryption Algorithms

Wireless encryption protects against eavesdropping and unauthorized access to wireless networks.

- **WEP (Wired Equivalent Privacy):**
 - An old, vulnerable encryption algorithm for 802.11 WLANs.

- it was designed to provide a wireless LAN with a level of security and privacy comparable to that of a wired LAN
- WEP uses a 24-bit initialization vector (IV) to form stream cipher RC4 for confidentiality and the CRC-32 checksum for integrity of wireless transmissions
- It has significant vulnerabilities and design flaws and can therefore be easily cracked
- Flaws:
 - No defined method for encryption key distribution.
 - Weak PSK changes.
 - RC4 can be used in a more randomized environment.
 - Attackers can analyze traffic to compute the key.
 - Key scheduling algorithms are vulnerable.
 - CRC-32 checksum is a weak integrity check.
 - IV reuse leads to plaintext attacks.
 - Standard does not require unique IVs.
 - RC4 is a one-time cipher.
 - No replay protection.
 - Supports only one-way authentication.
- WPA (Wi-Fi Protected Access):
 - A security protocol for 802.11 standard, designed to address WEP's weaknesses.
 - Uses TKIP (Temporal Key Integrity Protocol) for encryption and MIC (Message Integrity Check).
 - it uses a Temporal Key Integrity Protocol (TKIP) that utilizes the RC4 stream cipher encryption with 128-bit keys and 64-bit MIC integrity check to provide stronger encryption and authentication
 - WPA uses TKIP to eliminate the weaknesses of WEP by including per-packet mixing functions, message integrity checks, extended initialization vectors, and re-keying mechanisms
 - TKIP: Uses 128-bit keys and a per-packet key mixing function to prevent replay attacks.
 - MIC: Provides integrity check to prevent data tampering.
 - Weaknesses: Still vulnerable to dictionary/password-cracking attacks if PSK is weak. Can be vulnerable to packet spoofing/decryption in certain scenarios.
- WPA2 (Wi-Fi Protected Access 2):
 - Security protocol used to safeguard wireless networks, mandating IEEE 802.11i standard.
 - Uses AES (Advanced Encryption Standard) for strong security and CCMP (Counter Mode Cipher Block Chaining Message Authentication Code Protocol) for strong encryption.
 - Modes of Operation:
 - WPA2-Personal (PSK): Uses a pre-shared key (PSK) (256-bit ASCII or 64-hexadecimal characters). to protect unauthorized network accesses. In PSK mode, each wireless

network device encrypts the network traffic using a 128-bit key, which is derived from a passphrase of 8 to 63 ASCII characters

- WPA2-Enterprise: Integrates EAP (Extensible Authentication Protocol) and RADIUS server for centralized authentication using multiple authentication methods, such as token cards, and Kerberos. Users are assigned login credentials by a centralized server, which they must present when connecting to the network

- Issues: Still vulnerable to weak passwords, Man-in-the-Middle (MITM), DoS, and KRACK (Key Reinstallation Attack) vulnerabilities. Predictability of Group Temporal Key (GTK).

- **WPA3 (Wi-Fi Protected Access 3):**

- Advanced implementation of WPA2, announced in 2018.
- Uses **AES-GCM-256** encryption algorithm.
- **Modes of Operation:**
 - **WPA3-Personal:** Uses **SAE (Simultaneous Authentication of Equals)** protocol (Dragonfly Key Exchange) for stronger password-based authentication, resistant to dictionary attacks and offline brute-force attacks.
 - **WPA3-Enterprise:** Provides enhanced protection for sensitive data using advanced cryptographic algorithms (GCMP-256, HMAC-SHA-384). It provides authenticated encryption using GCMP-256. It uses HMAC-SHA-384 to generate cryptographic keys. It uses ECDSA-384 for exchanging keys.
- Enhancements over WPA2:
 - SAE: Stronger password authentication.
 - Wi-Fi Easy Connect: Simplifies device onboarding using QR codes.
 - OWE (Opportunistic Wireless Encryption): Provides better data privacy in public hotspots (unauthenticated encryption).
 - Bigger session keys: Increased key size.
- Limitations: Limited adoption, resource intensive, configuration errors can impact benefits, timing attacks, cache-based side-channel attacks, transition mode weaknesses (compatibility with older devices), hardware requirements.

Comparison of WEP, WPA, WPA2, and **WPA3**

Encryption	Attributes				
	Encryption Algorithm	IV Size	Encryption Key Length	Key Management	Integrity Check Mechanism
WEP	RC4	24-bits	40/104-bits	None	CRC-32
WPA	RC4, TKIP	48-bits	128-bits	4-way handshake	Michael algorithm and CRC-32
WPA2	AES-CCMP	48-bits	128-bits	4-way handshake	CBC-MAC
WPA3	AES-GCMP 256	Arbitrary length 1 - 2 ⁶⁴	192-bits	ECDH and ECDSA	BIP-GMAC-256

WEP, WPA	X	Should be replaced with more secure WPA2 and WPA3
WPA2	✓	Incorporates protection against forgery and replay attacks
WPA3	✓	Provides enhanced password protection and secured IoT connections; encompasses stronger encryption techniques

RADIUS: It is a centralized authentication and authorization management system.

PEAP: It is a protocol that encapsulates the EAP within an encrypted and authenticated Transport Layer Security (TLS) tunnel.

LEAP: It is a proprietary version of EAP developed by Cisco.

CCMP: It is an encryption protocol used in WPA2 for stronger encryption and authentication.

Issues with WEP, WPA, WPA2, and WPA3

Issues with WEP

- CRC-32 does not ensure complete cryptographic integrity
- IVs are 24 bits and sent in cleartext
- Vulnerable to **known plaintext attacks**
- Prone to **password cracking attacks**
- Associate/disassociate messages are not authenticated
- One can easily construct a decryption table of reconstructed key streams
- Lack of centralized key management
- IV is a part of the RC4 encryption key, which leads to an **analytical attack**

Issues with WPA

- Pre-shared key is vulnerable to **eavesdropping** and **dictionary attacks**
- Lack of forward secrecy
- WPA-TKIP is vulnerable to **packet spoofing** and decryption attacks
- Insecure random number generator (RNG) in WPA allows the **discover of GTK** generated by AP
- Vulnerabilities in TKIP allow attackers to guess the IP address of the subnet

Issues with WPA2

- Pre-shared key is vulnerable to eavesdropping and **dictionary attacks**
- Lack of forward secrecy
- Hole96 vulnerability makes WPA2 vulnerable to **MITM and DoS attacks**
- Insecure random number generator (RNG) in WPA2 allow attackers to **discover GTK** generated by AP
- **KRACK vulnerabilities** make WPA2 vulnerable to packet sniffing, connection hijacking, malware injection, and decryption attacks

Issues with WPA3

- WPA3 uses more complex **encryption algorithms**, which can demand more **processing power** from devices
- Simultaneous **Authentication of Equals (SAE)** vulnerable to **timing attacks**
- Vulnerable to **cache-based side-channel** attacks, exposing sensitive information from **cache access patterns**
- Errors in configuration such as **weak passwords** and **poor network setup**, can leave networks vulnerable to intrusion, despite the advanced protections offered by **WPA3**

3. Wireless Threats

Wireless networks are vulnerable to various attacks due to their nature.

Access Control Attacks: Wireless access control attacks aim to penetrate a network by evading WLAN access control measures, such as AP MAC filters and Wi-Fi port access controls

- **MAC Spoofing:** Changing MAC address to impersonate an authorized device or bypass MAC filtering.
- **AP Misconfiguration:** Misconfigured APs (e.g., default SSIDs, weak passwords, configuration errors) make networks vulnerable.
- **Ad Hoc Associations:** Direct client-to-client connections bypassing APs, often unencrypted.
- **Promiscuous Client:** A client in promiscuous mode can observe network traffic (passive sniffing).
- **Client Mis-association:** Client intentionally/accidentally connects to a rogue AP or unapproved network.
- **Unauthorized Association:** Attacker connects to a wireless network without authorization using various methods (e.g., creating a rogue AP).

Integrity Attacks: In integrity attacks, attackers send forged control, management, or data frames over a wireless network to misdirect the wireless devices to perform another type of attacks (e.g., DoS)

- **Data-Frame Injection:** Injecting forged 802.11 frames.(Airpwn-ng, Wperfb)
- **WEP Injection:** Injecting crafted WEP encryption keys.(WEP cracking + injection tools)
- **Bit-Flipping Attacks:** Flipping bits in encrypted data to alter plaintext without knowing the key.
- **Extensible AP Replay:** Replaying 802.1X Extensible Authentication Protocol (EAP) messages.(Wireless capture + injection tools between client and AP)
- **Data Replay:** Replaying captured 802.11 data frames.(Capture + injection tool)

- **Initialization Vector (IV) Replay:** Deriving the keystream by sending a plaintext message and replaying IVs.
- **RADIUS Replay:** Replaying RADIUS Access-Accept or Reject messages.(Ethernet capture + injection tools between AP and authentication server)
- **Wireless Network Viruses:** Malware designed to spread across wireless networks.

Confidentiality Attacks

These attacks intercept confidential information sent over a wireless network, regardless of encryption.

- **Eavesdropping:** Capturing and decoding unprotected wireless traffic.(Wireshark, Ettercap, Kismet, commercial analyzer)
- **Traffic Analysis:** Inferring information from observing network traffic characteristics.(Wireshark, Ettercap, Snort)
- **Cracking WEP Key:** Decrypting WEP keys.(Aircrack-ng, WEPCrack)
- **Evil Twin AP:** Attacker sets up a rogue AP with the same SSID as a legitimate AP to lure victims and steal credentials (phishing).(Hostapd, EvilTwinFramework, Wifiphisher)
- **Honeypot AP:** Setting up a decoy AP to gather attacker information.(Manipulating SSID)
- **Session Hijacking:** Taking over an established wireless session.(Manipulating)
- **Masquerading:** Pretending to be an authorized user/device.(Stealing login IDs and passwords, bypassing authentication mechanisms)
- **MITM Attack:** Intercepting and potentially altering wireless communications.(dsniff, Ettercap, aLTER attack)
- **aLTER Attack:** A virtual (fake) communication tower to intercept wireless communication, manipulate traffic, and redirect to malicious websites.

Availability Attacks

These attacks obstruct the delivery of wireless services to legitimate users (DoS) either by crippling those resources or by denying them access to WLAN resources.

- **Access Point Theft:** Physically removing an AP.
- **Disassociation Attacks:** Destroying connectivity between an AP and client.
- **De-authentication Attacks:** Flooding clients with forged de-authentication messages to disconnect them from an AP.
- **EAP-Failure:** Exploiting EAP to cause DoS.
- **Beacon Flood:** Generating thousands of counterfeit 802.11 beacons to make it difficult to find a legitimate AP.
- **Denial-of-Service (DoS):** Overwhelming the wireless network with traffic (e.g., jamming, signal flooding).

- **Routing Attacks (Wormhole Attack, Sinkhole Attack):** Exploiting routing protocols to redirect traffic or create black holes.
- **Authenticate Flood:** Sending forged authenticate messages to exhaust AP's association table.
- **ARP Cache Poisoning Attacks:** Poisoning ARP cache on wireless devices.
- **Power Saving Attacks:** Manipulating power-saving mechanisms to cause DoS.
- **TKIP MIC Exploit:** Generating invalid TKIP data to suspend WLAN service.

Authentication Attacks

These attacks steal Wi-Fi client identities and login information to gain unauthorized access.

- **PSK Cracking:** Recovering WPA PSK from captured key handshakes (brute-force/dictionary).
- **LEAP Cracking:** Recovering user credentials from LEAP.
- **VPN Login Cracking:** Cracking VPN credentials.
- **Domain Login Cracking:** Recovering Windows domain login hashes.
- **Key Reinstallation Attack (KRACK):** Exploiting vulnerabilities in the WPA2 four-way handshake to reinstall keys, allowing traffic decryption and injection.
- **Identity Theft:** Capturing user identities from 802.1X traffic.
- **Shared Key Guessing:** Cracking WEP keys.
- **Password Speculation:** Guessing passwords based on 802.11 traffic.
- **Application Login Theft:** Capturing user credentials from application protocols.

Wireless Specific Attacks

- **Honeypot AP Attack:** Attacker creates a rogue AP masquerading as a legitimate one to lure victims and steal information.
- **Wormhole Attack:** Exploiting routing protocols to create a "wormhole" tunnel, redirecting traffic through an attacker-controlled node.
- **Sinkhole Attack:** Advertising a compromised node as the best possible route to the base station, attracting all traffic.
- **Inter-Chip Privilege Escalation/Wireless Co-Existence Attack:** Exploiting vulnerabilities in wireless chips (e.g., Bluetooth/Wi-Fi combo chips) to gain privilege escalation.

4. Wireless Hacking Methodology

A systematic process to compromise a Wi-Fi network.

1. **Wi-Fi Discovery / Wireless Network Footprinting:**
 - Attacker starts by discovering Wi-Fi networks and locating/analyzing them.
 - **Passive Footprinting:** Detecting APs and clients by sniffing existing traffic without injecting packets.

- **Active Footprinting:** Sending probe requests with spoofed SSIDs to gather responses from APs.
- **WarWalking:** Attackers walk around with Wi-Fi-enabled laptops installed with a wireless discovery tool to map out open wireless networks
- **WarChalking:** Marking areas with Wi-Fi availability.
- **WarDriving:** Driving around with Wi-Fi-enabled laptops to map open wireless networks.
- **WarFlying:** Using drones to detect open wireless networks.
- **WPS (Wi-Fi Protected Setup) Enabled APs:** Identifying APs with WPS enabled, which is vulnerable to brute-force attacks.
- **Tools:** insider(inspects WLAN and surrounding networks to troubleshoot competing AP), NetSurveyor, Wi-Fi Scanner, WiFi Analyzer(Mobile-based Wi-Fi Discovery Tools), Opensignal, Network Signal Info Pro
- Attackers use Wash utility to identify the WPS-enabled APs and detect if the AP is in locked or unlocked state
 - Most of the WPSs in the routers usually lock when brute-forced for more than five times and can be unlocked only in the administrator interface of the router manually
 - The Wash command can support the 5 GHz channel
 - The attacker discovers the AP, ESSID, and BSSID of a device or router using the following wash command • # sudo wash -i wlan0

2. Wireless Traffic Analysis:

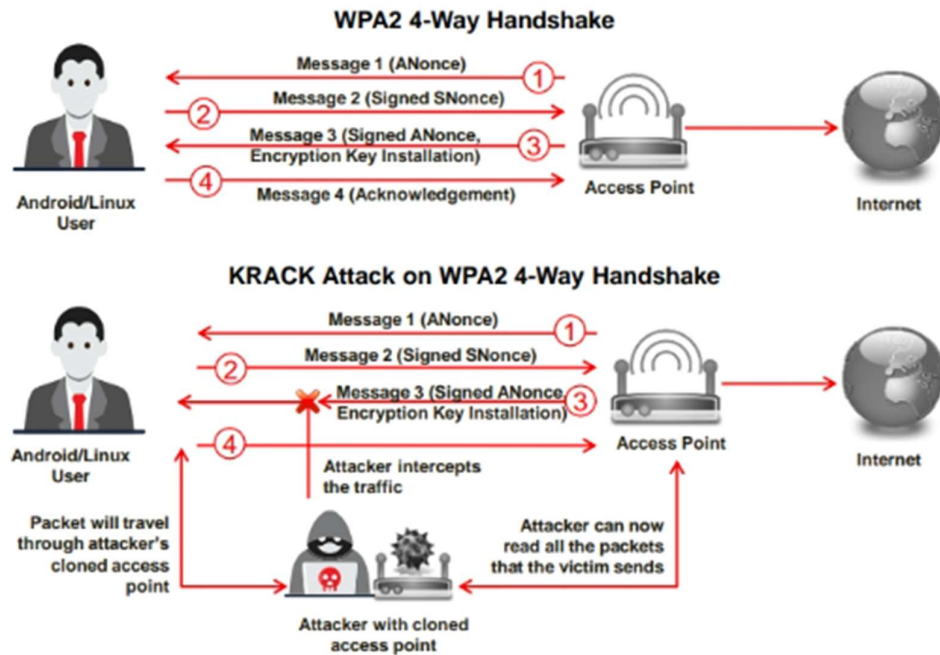
- Capturing and analyzing wireless traffic to identify vulnerabilities, connected clients, and encryption methods.
- Attackers analyze a wireless network to determine the broadcast SSID, presence of multiple access points, possibility of recovering SSIDs, authentication method used, WLAN encryption algorithms, etc.
- Attackers use Wi-Fi packet analyzer tools, such as AirMagnet G3 Pro, Wireshark, OmniPeek, and CommView for Wi-Fi, to capture and analyze the traffic of a target wireless network
- Tools: Wireshark, Riverbed Packet Analyzer, OmniPeek Network Protocol Analyzer, CommView for Wi-Fi, Kismet, Acrylic Wi-Fi Analyzer, airogeddon.
- Choosing Optimal Wi-Fi Card: Selecting a wireless card that supports packet injection and monitoring.
- Spectrum Analysis: Analyzing RF spectrum for interference and potential vulnerabilities. Tools: RF Explorer, Chanalyzer, AirCheck G3 Pro, Spectraware S1000, RSA306B USB Spectrum Analyzer, Monics, Signal Hound, FIELDSENSE.

3. Launch of Wireless Attacks:

- **Aircrack-ng Suite:** A comprehensive suite of tools for Wi-Fi auditing and cracking (Airodump-ng, Aircrack-ng, Aireplay-ng, Airbase-ng, Airmo-n-ng, Airodump-ng, Airolib-ng, Airtun-ng).

Airbase-ng	Captures WPA/WPA2 handshake and can act as an ad-hoc AP	Aireplay-ng	Effective for gathering WEP IVs and WPA handshakes
Aircrack-ng	De facto WEP and WPA/WPA2-PSK cracking tool	Airmon-ng	Used to enable monitor mode on wireless interfaces from managed mode and vice versa
Airdecap-ng	Decrypts WEP/WPA/WPA2 and can be used to strip the wireless headers from Wi-Fi packets	Airodump-ng	Used to capture packets of raw 802.11 frames and collect WEP IVs
Airdrop-ng	Used for targeted, rule-based de-authentication of users	Airolib-ng	Stores and manages ESSID and password lists used in WPA/WPA2 cracking https://www.aircrack-ng.org

- Detection of Hidden SSIDs: Using airodump-ng to discover hidden SSIDs.
- Denial-of-Service: Wireless DoS attacks include disassociation attacks and de-authentication attacks.
 - In a disassociation attack, the attacker makes the victim unavailable to other wireless devices by destroying the connectivity between the AP and client.
 - In a de-authentication attack, the attacker floods station(s) with forged de-authenticates or disassociates to disconnect users from an AP.
- Man-in-the-Middle Attack: MITM attacks are associated with 802.11 WLANs as well as wired communication systems. ☺ Eavesdropping ☺ Manipulation
- MAC Spoofing Attack (AP MAC Spoofing): Impersonating APs by changing MAC addresses. To spoof a MAC address, the attacker needs to set the value returned from ifconfig to another hex value in the format of aa:bb:cc:dd:ee:ff Tools: Technitium MAC Address Changer.
 - Technitium MAC Address Changer allows you to change (spoof) the MAC Address of your Network Interface Card (NIC) instantly
- Wireless ARP Poisoning Attack: Spoofing ARP packets on wireless networks to redirect traffic. Tools: arpspoof, Ettercap.
- Rogue APs: A rogue AP provides backdoor access to the target wireless network. Setting up unauthorized APs to lure clients and steal data. Tools: MANA Toolkit (hostapd-mana.conf, start-nat-simple.sh).
- Evil Twin Attack: Creating a rogue AP with the same SSID as a legitimate one to trick users. Evil Twin can be configured with a common residential SSID, hotspot SSID, or a company's WLAN SSID
- Key Reinstallation Attack (KRACK): Exploiting WPA2 four-way handshake vulnerability.



- **Jamming Signal Attack:** Overloading wireless network frequencies to cause DoS. Tools: Wi-Fi jamming devices (e.g., CPB-4510 Jammer). This jamming signal causes a DoS because 802.11 is a CSMA/CA protocol whose collision avoidance algorithms require a period of silence before a radio is allowed to transmit
- **Wi-Fi Jamming Devices**
 - PCB-4510 Jammer • Range: 50–150 m • 10 Antennas
 - CPB-2920 Jammer • Range: 10–40m • 20 Antennas
 - CPB-2612H-5G Jammer
- **aLTER Attack:** Virtual communication tower for MITM attacks on LTE/4G/5G. Attacker installs a virtual (fake) communication tower between two authentic endpoints intending to mislead the victim. This virtual tower is used to interrupt the data transmission between the user and real tower attempting to hijack the active session. An aLTER attack has the following two phases.
 - **Information gathering phase:** Attackers passively gather information needed to perform an aLTER attack using techniques such as identity mapping and website fingerprinting.
 - **Attack phase:** Attackers use the information gathered to perform an active attack using techniques such as DNS spoofing.
- **Wi-Jacking Attack:** In this attack, the Wi-Fi information of the nearest victims can be retrieved without using any cracking mechanisms. This attack can be used when credentials are saved in the victim's browser, when the victim accesses the same website multiple times
- **RFID Cloning Attack:**
 - RFID cloning involves capturing the data from a legitimate RFID tag and then creating its clone using a new chip
 - Attackers use tools such as iCopy-X and RFIDlerto to clone RFID tags
 - iCopy-X is an entirely stand-alone and portable RFID cloning device that can be used by attackers to clone RFID tags

Wi-Fi Encryption Cracking: WPA/WPA2

Encryption **Cracking**

WPA PSK

WPA PSK uses a **user-defined password** to initialize the TKIP, which is not crackable as it is a per-packet key, but the keys can be brute-forced using dictionary attacks

Offline Attack

You only required to be near the AP for a matter of seconds to capture the **WPA/WPA2 authentication handshake**; by capturing the right type of packets, you can **crack the WPA keys offline**

De-authentication Attack

Force the connected client to disconnect. Then, capture the re-connect and authentication packets using tools, such as **aireplay**; you should be able to re-authenticate in a few seconds. Then **attempt to dictionary brute-force** the PMK

Brute-Force WPA Keys

You can use tools, such as **aircrack** and **aireplay** to brute-force WPA Keys

7. Wireless Security: WPA3 Encryption

CC-0 BY-NC-SA

WPA3 Encryption **Cracking**

- **Dragonblood** is a set of **vulnerabilities in the WPA3** security standard that allows attackers to **recover keys, downgrade security mechanisms**, and launch various information-theft attacks
- Attackers can use various tools, such as **Dragonslayer**, **Dragonforce**, **Dragondrain**, and **Dragontime**, to exploit these vulnerabilities and launch attacks on WPA3-enabled networks

Downgrade Security Attacks

- **Exploiting Backward Compatibility**
 - An attacker installs a rogue AP and forces the user to involve in WPA2 encryption
 - Then, the attacker performs all the attacking techniques available to exploit WPA2
- **Exploiting the Dragonfly Handshake**
 - An attacker with a rogue AP discards the user's WPA3 Dragonfly mechanism
 - The attacker forces the user to use a weaker encryption algorithm, such as WPA2, and exploits WPA2

Side-channel Attacks

- **Timing-Based**
 - An attacker analyzes the amount of time dragonfly handshake takes for certain password authentications
 - The attacker notices the number of iterations the encoding process takes and short-lists the passwords to launch further attacks
- **Cache-Based**
 - An attacker installs malicious JavaScript code on the client's browser and observes memory access patterns
 - The attacker retrieves the passwords to perform malicious actions with the user's credentials

5. Wireless Attack Countermeasures

Implementing multi-layered security measures is crucial.

Wireless Encryption & Authentication Countermeasures

- **Use Strong Encryption (WPA2-Enterprise or WPA3):** Always prefer WPA3-Enterprise or WPA2-Enterprise with strong authentication (EAP-TLS, PEAP) and a RADIUS server.
- **Strong Passwords for WPA2-Personal/WPA3-Personal:** Use complex, long pre-shared keys.
- **Regular Key Rotation:** Change keys periodically.
- **Enable MAC Address Filtering:** Restrict access to known MAC addresses (can be bypassed by spoofing).

- **Disable SSID Broadcast:** Hiding the SSID makes network discovery slightly harder, but does not prevent determined attackers.
- **Use Centralized Authentication (RADIUS/EAP):** For enterprise environments.
- **Implement 802.1X:** Port-based network access control.

Network Configuration & Management

- **Change Default Settings:** Change default SSIDs, passwords, and admin credentials on APs.
- **Proper AP Placement:** Place APs strategically to avoid signal leakage outside the desired coverage area.
- **Network Segmentation (VLANs):** Isolate wireless network traffic from the wired network.
- **Firewalls and IDS/IPS:** Implement firewalls to filter wireless traffic and IDS/IPS to detect suspicious activity.
- **Disable WPS:** WPS is vulnerable to brute-force attacks.
- **Disable Unused Services on APs.**
- **Physical Security:** Secure APs against physical tampering or theft.
- **Regular Firmware Updates:** Keep APs and wireless devices updated.
- **Monitor Wireless Logs:** For unusual activity.

Client-Side Countermeasures

- **Disable Auto-Connect to Unknown Networks.**
- **Verify AP Authenticity:** Be cautious of suspicious or unauthenticated APs (Evil Twins).
- **Use VPNs (Virtual Private Networks):** Encrypt traffic over untrusted wireless networks.
- **Keep OS and Client Software Updated:** Patch vulnerabilities in wireless drivers and OS.
- **Personal Firewalls:** On client devices.
- **User Awareness Training:** Educate users about wireless threats (Evil Twin, phishing).
- **Strong Password for Wi-Fi Networks.**
- **Disable Ad Hoc Mode on Clients:** Prevent unauthorized direct connections.
- **Use Digital Certificates for Authentication.**

Countermeasures for Specific Attacks

- **Against MAC Spoofing:** Implement 802.1X with centralized authentication, or use port security on switches (if AP is wired).
- **Against Evil Twin:** Educate users to verify network names, use VPNs, and disable auto-connect. Use wireless IDS/IPS.
- **Against KRACK:** Apply patches immediately to all Wi-Fi devices.

- **Against Jamming:** Use spread spectrum technologies, signal hopping, and consider spectrum analysis tools.

Wireless Security Tools (Countermeasures/Detection)

- **Wi-Fi Auditors:** (e.g., Aircrack-ng, inSSIDer, NetSurveyor).
- **Wireless IDS/IPS:** (e.g., Cisco Wireless IPS, AirTight Networks, Wireless Guard).
- **Wireless Security Gateways:** (e.g., SonicWall Wireless Network Security, FortiAP).
- **Endpoint Protection:** On client devices (antivirus, host-based firewalls).